Unidad 3:

LAB-02 — Trazabilidad en MongoDB Community.

Actividad 7:

Cambios de privilegios: el límite más importante.

Alumno: Cesar Alberto Lopez Zavala. Fecha: 24/10/2026.

Preguntas:

¿Por qué un cambio de privilegios es uno de los eventos auditables más importantes?

Porque la escalación de privilegios permite a un usuario eludir cualquier control de seguridad.

Un usuario que se otorga a sí mismo permisos de administrador puede acceder a datos confidenciales, destruir información y borrar sus propias huellas para salir impune.

¿Con qué frecuencia tomarías instantáneas? ¿Qué factores influyen?

Lo ideal sería automatizarlo (mediante un script) para que se ejecute cada hora o al menos una vez al día, influye directamente el nivel de riesgo que la empresa esté dispuesta a aceptar, la criticidad de la información y la carga extra que estas consultas constantes generen en el servidor.

¿Quién debería poder escribir en auditoria.instantaneas_privilegios?

Estrictamente un proceso automatizado o una cuenta de servicio dedicada exclusivamente a la auditoría, ningún usuario humano (ni siquiera los DBAs con permisos altos) debería tener permisos de modificación o borrado sobre esta colección, para garantizar el principio de inmutabilidad de la evidencia.

Redacta en tres líneas cómo comunicarías esta limitación a Dirección:

"MongoDB Community Edition carece de auditoría nativa para rastrear quién y cuándo modifica los permisos de los usuarios. Aunque implementamos un control que detecta alteraciones recientes, es imposible identificar al responsable exacto de

una brecha. Para cumplir con normativas de seguridad estrictas, recomendamos evaluar la versión Enterprise."

Evidencia de ejecución:

```
comercial> db.getSiblingDB("auditoria").instantaneas_privilegios.insertOne({
|   momento: new Date(),
|   tomada_por: db.runCommand({ connectionStatus: 1 }).authInfo.authenticatedUsers,
|   usuarios: db.getUsers().users.map(u => ({ user: u.user, db: u.db, roles: u.roles }))
| })
{
  acknowledged: true,
  insertedId: ObjectId('6af143a0e375cc27eefab03d')
}
comercial>

comercial> db.setProfilingLevel(2)
{
  was: 1,
  slowms: 100,
  sampleRate: 1,
  filter: { op: { '$in': [ 'insert', 'remove', 'update' ] } },
  note: 'When a filter expression is set, slowms and sampleRate are not used for profiling and slow-query log lines.',
  ok: 1
}
comercial> db.grantRolesToUser("app_ventas", [{ role: "dbAdmin", db: "comercial" }])
{ ok: 1 }
comercial> db.system.profile.countDocuments({ "command.grantRolesToUser": { $exists: true } })
0
comercial> bitacora().filter(e => JSON.stringify(e).includes("grantRoles")).length
0
comercial>

comercial> db.getSiblingDB("auditoria").instantaneas_privilegios.insertOne({
|   momento: new Date(),
|   tomada_por: db.runCommand({ connectionStatus: 1 }).authInfo.authenticatedUsers,
|   usuarios: db.getUsers().users.map(u => ({ user: u.user, db: u.db, roles: u.roles }))
| })
{
  acknowledged: true,
  insertedId: ObjectId('6af14407e375cc27eefab03e')
}
```

```
comercial> db.getSiblingDB("auditoria").instantaneas_privilegios.find(
[
  {
    momento: ISODate('2026-11-09T03:53:04.962Z'),
    tomada_por: [ { user: 'admin', db: 'admin' } ],
    usuarios: [
      {
        user: 'app_ventas',
        db: 'comercial',
        roles: [ { role: 'readWrite', db: 'comercial' } ]
      }
    ]
  },
  {
    momento: ISODate('2026-11-09T03:54:47.187Z'),
    tomada_por: [ { user: 'admin', db: 'admin' } ],
    usuarios: [
      {
        user: 'app_ventas',
        db: 'comercial',
        roles: [
          { role: 'dbAdmin', db: 'comercial' },
          { role: 'readWrite', db: 'comercial' }
        ]
      }
    ]
  }
]
```

```
comercial> db.revokeRolesFromUser("app_ventas", [{ role: "dbAdmin", db: "comercial" }])
{ ok: 1 }
comercial> db.setProfilingLevel(1, { filter: { op: { $in: ["insert", "update", "remove"] } } })
{
  was: 2,
  slowms: 100,
  sampleRate: 1,
  filter: { op: { '$in': [ 'insert', 'remove', 'update' ] } },
  note: 'When a filter expression is set, slowms and sampleRate are not used for profiling and slow-query log lines.',
  ok: 1
}
```